

AI Threat Modelling Guide

An integrated approach: STRIDE with the OWASP Top 10s for LLM and Agentic Applications, ATLAS and MAESTRO

STRIDE with the OWASP Top 10s

The systemic view. Suited to design, because it works from the system rather than from what has already happened.

What they cover

- Applied to every process, data store, external entity and flow, with particular weight at trust boundaries.
- The OWASP Top 10s add the AI risk classes: LLM01 to LLM10, and ASI01 to ASI10 for agents.
- Both work from the design rather than incident history, so they apply before anything is built.
- Each OWASP entry carries example attack scenarios and suggested mitigations.

Suited to structural coverage of the system as designed

Scope and limits

- The example scenarios are illustrative, rather than a catalogue of observed behaviour with identifiers to cite.
- Neither records which techniques have been seen in practice.
- STRIDE's categories predate instructions inside data, persistent memory and systems that act on their own. The OWASP lists cover that ground.
- Coverage comes from the architecture and the test evidence, not from the presence of a reference.

Less suited to describing observed adversary behaviour

In practice. The usual baseline for anything being designed or changed, and the form an assurance reviewer is most likely to recognise.

MITRE ATLAS

The operational view. Adversary behaviour against AI systems, graded by how well established each item is.

How it works

- Sixteen tactics form the columns. Techniques are listed beneath them, and are what practitioners cite.
- Platform tags narrow the matrix to those relevant to generative and agentic systems.
- Maturity is graded Feasible, Demonstrated and Realized.
- Case studies give dated precedent, and the shape is shared with Enterprise ATT&CK.

Suited to citing attacks observed or demonstrated

Scope and limits

- Entries follow evidence, so coverage is thinner where the incident record is young.
- Organised around observed behaviour rather than system structure.
- Design properties map less directly, so the crosswalk that follows is indicative.
- Non-adversarial failure falls outside its scope: goal drift, reward hacking, cascades without an attacker. *Some harmful autonomous behaviour is not fully covered.*

Less suited to reasoning about types of systems with no incident records

Challenges with ATLAS. In a 2025 prototype, fabricated entries in an agent's history file led it to over-estimate the threat level and extend packet captures, degrading detection and exhausting resources without any change to system logic. (Zambare et al., arXiv:2508.10043, 2025) *Cascading failures and inter-agent communication have no direct ATLAS technique.*

A threat derived from the architecture remains valid whether or not ATLAS records it.

MAESTRO

The layered view. A way to scan an architecture, layer by layer and then across layers.

How it works

- Seven layers, from foundation models through to the agent ecosystem, with security and compliance as a vertical.
- Each layer is questioned in turn, then across layers for propagation.
- This course uses OWASP identifiers as the common vocabulary across the layers.
- Working from architecture rather than evidence, it can raise a threat class before any incident exists.

Suited to finding cross-layer paths that per-component analysis can miss

Scope and limits

- Young and not formally validated: results vary between practitioners.
- The layers cover the AI system. Keep conventional application, session and access-control checks alongside them.
- Layers are not trust boundaries, and one can span several trust domains.
 - Trust boundaries can be missed with varying results
- It works best against a system that exists.

Less suited to covering the system around the AI, and as a repeatable process

In practice. Used as validation after the model is drafted but it can also work as the primary scan for red teaming

Applying MAESTRO: One question per layer, then across layers

L1 - Foundation models

Could crafted input or retrieved content change what the model is trying to do? Is the model's provenance and version known?

L2 - Data operations

What can write into the data the agent reads or remembers - corpus, embeddings, memory? Would poisoned content persist?

L3 - Agent frameworks

Which tools can the agent call, what validates their arguments, and how are new tools discovered and trusted?

L4 - Deployment and infrastructure

Where does the agent runtime run, and what can it reach - network egress, credentials and secrets, environment isolation, production systems?

L5 - Evaluation and observability

Would drift or misuse be noticed? What telemetry exists per agent, and who reviews it?

L6 - Security and compliance

Agent identity, user delegation, authorisation and policy enforcement: is each action attributable and authorised? Cross-cutting.

L7 - Agent ecosystem

External agents, agent-to-agent communication, capability discovery, delegation and transitive trust: who is trusted, and how far does it carry?

Across layers

Could compromise in one layer propagate through another into data exposure, unauthorised action or wider system failure?

MAESTRO: The layer view

Layer	Findings and OWASP references	Owner	Action
L1 Foundation models	<i>e.g. goal hijack via retrieved content (ASI01)</i>		
L2 Data operations	<i>e.g. open write path to the corpus (ASI06, LLM04)</i>		
L3 Agent frameworks	<i>e.g. free-form tool arguments (ASI02)</i>		
L4 Deployment and infrastructure	<i>e.g. runtime credentials reach production (ASI03, ASI05)</i>		
L5 Evaluation and observability	<i>e.g. no per-agent telemetry (Gov)</i>		
L6 Security and compliance	<i>e.g. no user delegation on agent actions (ASI03)</i>		
L7 Agent ecosystem	<i>e.g. transitive trust in an external agent (ASI07)</i>		
Across layers	<i>e.g. poisoned memory drives an authorised tool call (ASI06 to ASI02)</i>		

Considered with none found is a legitimate outcome, provided the reason is recorded.

Two halves of one picture

The structural side describes what could fail. The adversarial side shows how it would be reached. Together they give a stable view.

Structural - STRIDE with the OWASP Top 10s

- Works from the system as designed: components, flows, trust boundaries, and the AI risk classes on top.
- Produces the threat model, and with it what must be tested.
- Applies whether or not anything has ever been attacked, which is why it works before a system is built.
- This is the threat model in this Deep Cyber adaptation; the validation step then tests it.

Structural what could fail, and what must be tested

Validation - ATLAS / ATT&CK and/or MAESTRO

- MAESTRO's seven layers enumerate the surface, so the pass is systematic rather than wherever instinct points.
- ATLAS supplies documented adversary techniques against AI systems; ATT&CK covers conventional cyber, as STRIDE does.
- Produces attack paths, and with them how the system would be reached.

Adversarial how it would be reached, and how it would look

When to run the adversarial validation. Handing over to operations before deployment, to build monitoring and playbooks. Red-team and purple-team exercises. Teaching people how an attack actually unfolds. After a material change, such as a new tool or connector. And when an incident is published elsewhere and the question is whether it could happen here.

An integrated method

Two steps, in this Deep Cyber adaptation. The first produces the threat model; the second validates it.

Step 1 Threat model

STRIDE with the OWASP Top 10s, worked through the Threat Navigator by solution type. One conventional threat model, extended for AI. The navigator's baseline questions are its first step. The navigator is also the reference for the threat types and their mitigations.

Produces: A threat model with OWASP references

Step 2 Validation

ATLAS challenges the model with documented adversary techniques and case studies. Where the solution is agentic, MAESTRO's layers are added so the pass covers the surface systematically.

Produces: Attack paths, telemetry and test scenarios

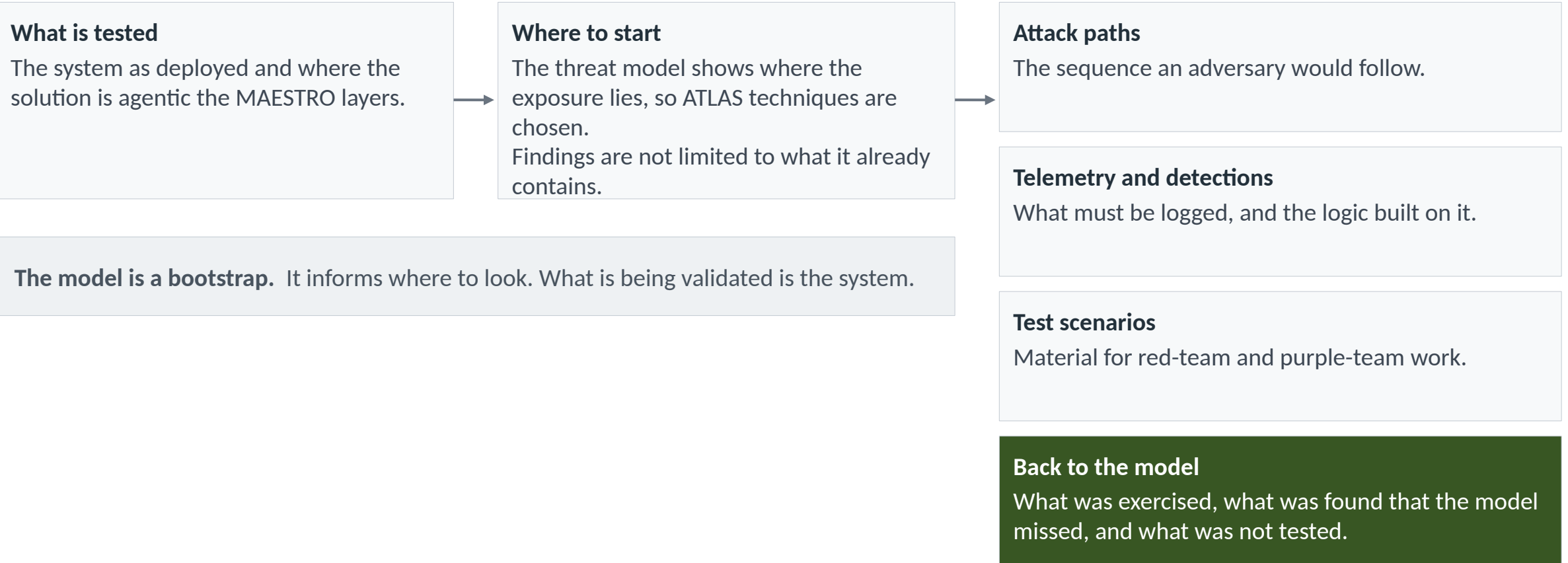
MAESTRO. Added where there is retrieval, memory, tools or autonomous planning.

Automation. Both steps can be run with an AI assistant. A guided skill asks the navigator questions and drafts the model, which the practitioner then reviews and owns.

Worked example. The companion Worked Example Workbook runs both steps on Larkfield and Deep Vault Capital.

Adversarial validation using ATLAS

The system is tested against documented adversary behaviour. The threat model gives the starting point



Mitigations are held in the playbooks for the solution type.

ATLAS techniques by MAESTRO layer

A starting point for choosing what to exercise at each layer. Deep Cyber's indicative candidate mappings, not a mapping published by MITRE or CSA.

Layer	ATLAS techniques to consider
L1 Foundation models	T0051.001 indirect prompt injection · T0054 jailbreak · T0056 extract system prompt · T0018.003 modify prompt construction
L2 Data operations	T0070 RAG poisoning · T0071 false RAG entry · T0080.000 memory poisoning · T0020 training data poisoning
L3 Agent frameworks	T0053 tool invocation · T0084.001 tool definition discovery · T0110.002 tool response poisoning · T0086 exfiltration through a tool
L4 Deployment and infrastructure	T0050 command interpreter · T0072 reverse shell · T0105 escape to host · T0112.000 local agent compromise
L5 Evaluation and observability	T0031 erode model integrity · T0059 erode dataset integrity · T0062 discover hallucinations. Thin in ATLAS.
L6 Security and compliance	T0012 valid accounts · T0055 unsecured credentials · T0083 credentials from agent configuration · T0081 modify agent configuration
L7 Agent ecosystem	T0108 command and control through an agent · T0100 agent clickbait · T0067.000 manipulated citations · T0109 supply chain rug pull
Across layers	AML.T0061 covers prompt propagation and AML.T0034.002 covers delegation and fan-out; no single technique maps the whole chain, so chain those found above and test the sequence.

Use the platform tags to orient, but keep applicable Enterprise techniques such as valid accounts and access tokens; let the threat model set the order. Drift and telemetry at L5 are largely governance questions.

Recording the validation

What the pass produced, layer by layer. Techniques not exercised are recorded as such rather than left blank.

Layer	Techniques exercised	Evidence	Outcome
L1 Foundation models	T0051.001 indirect prompt injection, T0054 jailbreak		
L2 Data operations	T0070 RAG poisoning, T0080.000 memory poisoning		
L3 Agent frameworks	T0053 tool invocation, T0084.001 tool definition discovery		
L4 Deployment and infrastructure	T0112.000 local agent compromise		
L5 Evaluation and observability	None applicable		
L6 Security and compliance	T0012 valid accounts, T0091.000 application access token		
L7 Agent ecosystem	T0100 agent clickbait		
Across layers	T0070 RAG poisoning into T0053 tool invocation		

Close by reconciling against the threat model: which modelled threats were exercised, and which were not.

How MAESTRO is used in published practice

An author review, August 2026. The sample list and coding are not published here, so read it as an author's reading rather than formal validation.

Measure	Count
Written items examined	25
No mention of ATLAS at all	15
ATLAS named but no technique applied	7
Carrying ATLAS identifiers of any kind	3
Applying all seven layers to a system	9
Indexing threats to OWASP identifiers	6
Indexing to bespoke per-article identifiers	12
Items mapping ATLAS techniques onto the layers	1

This is the basis for calling MAESTRO young, and for describing the layer to technique table as indicative rather than settled.

Four solution types, and what each adds

Solution type	Additional emphasis	Adversarial validation
Constrained chatbot	Retrieval permissions and tenant isolation; output rendering; consumption limits; reliance on fabricated answers.	ATLAS alone; MAESTRO adds little
Enterprise assistant, M365 style	Oversharing and semantic discovery; connector ACL freshness; cross-source aggregation changing sensitivity; label and retention propagation.	ATLAS with MAESTRO; retrieval at scale
Single actionable agent	The commit boundary: deterministic authorisation before irreversible actions; idempotency and rollback; approval bound to the exact action.	ATLAS with MAESTRO
Multi-agent and A2A	Agent identity and attestation; delegation and capability attenuation; replay and downgrade; task isolation; cascade and fan-out limits.	ATLAS with MAESTRO, including across layers
Note. Every one of these still needs conventional application, API, cloud, identity and privacy threat modelling. The AI-specific passes are added on top of that, never instead of it.		

Frameworks and editions

[Method ›](#)

Framework	Edition used	Role in this method
OWASP Top 10 for LLM Applications	2025, v2.0	Seeds common risks; cited as LLM01 to LLM10
OWASP Top 10 for Agentic Applications	2026	Seeds agentic risks; cited as ASI01 to ASI10
MAESTRO	CSA, 2025	Seven-layer scan of the system as deployed
MITRE ATLAS	Content 2026.07	Challenges the findings with adversary behaviour
MITRE Enterprise ATT&CK	Current release	Conventional paths into and around the estate
AI Threat Navigator	v1.3	The working aid: questions, mitigations, ATLAS families
Worked Example Workbook	v1.3	The method applied end to end; selected mappings

Companion artefacts. The playbooks carry the controls and the lifecycle. The ATLAS edition is re-checked on each release.